

מודול 1 — מבוא, המעבדה ומתודולוגיה

חומר לימוד

1 יחידות

תוכן העניינים

1. מודול 1 — מבוא, המעבדה ומתודולוגיה

הכול בגלילה אחת: כל החומר של המודול בקובץ אחד — חומר לימוד, תרגילים, תרגול ופתרונות, ברצף.

🎬 **מודול מעשי!** אחרי מושגי המפתח יש בלוקים של “🎬 הדגמה — נסה בעצמך” עם הוראות צעד-אחר-צעד. כבר במודול הראשון **תפרוץ יעד אמיתי** (קובץ `first_hack.py`) ותקבל את הדגל הראשון שלך — עוד לפני שהמעבדה מוכנה. אחרי כל הדגמה יש שאלת 🧠 **בדוק את עצמך**. לומדים בעשייה.

מודול 1 — מבוא, המעבדה ומתודולוגיה

מטרות המודול: בסיום המודול תבין מהו האקינג אתי לעומק, תכיר את סוגי ההאקרים וסוגי בדיקות החדירה, תשלוט במתודולוגיית חמשת השלבים, תקים מעבדה וירטואלית מבודדת ותפעילה, ותתמצא ב-Kali Linux ובארגז הכלים שלו.

קבצים במודול: `README.md` (חומר לימוד) · `missions.md` (תרגילים) · `solutions.md` (פתרונות) · `practice.md` (תרגול) · `slides.md` (מצגת).

תוכן העניינים

0. 🎬 פתיחה — סיפורים שישנו את העולם
1. מהו האקינג אתי
2. סוגי האקרים (Threat Actors)
3. סוגי בדיקות חדירה
4. מושגי יסוד וטרמינולוגיה
5. חמשת שלבי ההאקינג האתי
6. היבטים משפטיים ואתיים
7. הקמת המעבדה
8. סקירת Kali Linux
9. סיכום ומילון מונחים

פתיחה — סיפורים שישנו את העולם 🎬

לפני ההגדרות והכלים — בואו נדבר על **למה** התחום הזה כל כך מרתק. כל סיפור כאן הוא אירוע אמיתי ששינה את העולם, וכל אחד מהם מתחבר ישירות למשהו שתלמדו בקורס הזה. 🌍

🐛 תולעת מוריס — הפעם הראשונה שהאינטרנט “נפל” (1988)

סטודנט בן 23 מאוניברסיטת קורנל בשם רוברט מוריס כתב תוכנית קטנה שנועדה רק “למדוד את גודל האינטרנט”. באג אחד בקוד גרם לה להשתכפל בטירוף — ותוך שעות היא שיתקה כ-6,000 מחשבים, **בערך 10% מכל האינטרנט של אז**. מוריס היה הראשון בהיסטוריה שהורשע לפי חוק הפריצה למחשבים בארה”ב. היום? הוא פרופסור מכובד ב-MIT. < 🍌 **בקורס:** כך בדיוק מתפשטות תולעות ו-Exploits — נלמד את המנגנון במודולים 6–7.

💌 ILOVEYOU — מכתב האהבה שהדביק 50 מיליון מחשבים (2000)

בוקר אחד קיבלו מיליוני אנשים מייל עם הכותרת “ILOVEYOU” וקובץ מצורף בשם “מכתב אהבה”. כל מי שפתח — הקבצים שלו נמחקו, והתולעת שלחה את עצמה לכל אנשי הקשר שלו. **50 מיליון מחשבים תוך 10 ימים, נזק של ~10 מיליארד דולר**. לא חולשה טכנית מתוחכמת — פשוט אנשים שסקרנים מדי ללחוץ. < 🍌 **בקורס:** זהו הגורם האנושי — **הנדסה חברתית ופשיננג** (מודול 15). האדם הוא תמיד החוליה החלשה.

☢️ Stuxnet — כשקוד הרס מכונות אמיתיות (2010)

נשק הסייבר הראשון בעולם שגרם **נזק פיזי**. תולעת מתוחכמת להפליא חדרה למתקן הגרעין באיראן, קפצה בין רשתות מבודדות דרך דיסקים-און-קי, וגרמה לצנטריפוגות להסתובב במהירות מטורפת עד שהרסו את עצמן — בזמן שהמסכים הראו למפעילים שהכול תקין. < 🍌 **בקורס:** קוד יכול לחצות מהעולם הדיגיטלי לעולם הפיזי. זו העוצמה — וזו האחריות.

🔒 WannaCry — הכופרה ששיתקה בתי חולים (2017)

תוך ימים ספורים נדבקו **מעל 200,000 מחשבים ב-150 מדינות**. הכופרה הצפינה קבצים ודרשה כופר בביטקוין. היא שיתקה בתי חולים בבריטניה — ניתוחים בוטלו, מטופלים הופנו לבתי חולים אחרים. איך היא התפשטה? דרך חולשה בשם **EternalBlue** (בפרוטוקול SMB) שדלפה מה-NSA. מיליוני מערכות פשוט לא עדכנו את התיקון שכבר היה זמין. < 🍌 **בקורס:** במודול 6 **תסקרו בעצמכם** מערכות ותחפשו את החולשה MS17-010 — **אותה חולשה בדיוק** ש-WannaCry ניצלה.

📷 Mirai — הצבא של המצלמות (2016)

קבוצת סטודנטים בנתה רשת בוטים שהשתלטה על **מאות אלפי מכשירי IoT** — מצלמות אבטחה, ראוטרים — פשוט על-ידי ניסיון סיסמאות ברירת מחדל כמו `admin/admin`. ואז הפעילה מתקפה שהפילה את

Spotify, Netflix, Reddit ו-Twitter בבת אחת ברחבי ארה"ב. < 📌 **בקורס:** סיסמאות חלשות וברירת מחדל — **מתקפות סיסמאות** (מודול 8). כלל אצבע: אם לא שינית את הסיסמה, מישוהו כבר יודע אותה.

147 — Equifax מיליון גנובים בגלל תיקון אחד שנשכח (2017)

אחת הפריצות החמורות בהיסטוריה: פרטים אישיים (כולל מספרי זהות) של **147 מיליון בני אדם** נגנבו. הסיבה? חולשה **אחת** ברכיב תוכנה (Apache Struts) שהתיקון עבורה היה זמין כבר חודשים — ופשוט לא הותקן. < 📌 **בקורס:** רכיבים פגיעים ועדכונים — **אבטחת Web** (מודול 9) וחקר חולשות (מודול 6).

קווין מיטניק — ההאקר המבוקש שהפך למגן

ההאקר המפורסם בעולם בשנות ה-90. הוא פרץ לעשרות חברות — אך **לרוב לא דרך קוד, אלא דרך אנשים:** שיחת טלפון משכנעת, התחזות, וקצת ביטחון עצמי. הוא היה על רשימת המבוקשים של ה-FBI, ישב 5 שנים בכלא — והיום הוא יועץ אבטחה מבוקש ומרצה. המסע מ"הרשע" ל"מגן" הוא בדיוק המסע של הקורס הזה. < 📌 **בקורס:** הכלי החזק ביותר הוא לפעמים פשוט לדעת לדבר עם אנשים.

💰 ולמה כדאי לכם? התחום שמשלם

- האקרים אתיים הם מהמקצועות **המבוקשים ביותר** בהייטק — מחסור עולמי של מיליוני אנשי אבטחה.
- **Bug Bounty:** חברות כמו Google, Facebook ו-Apple **משלמות** להאקרים שמוצאים אצלן חולשות — יש בני 17 שהרוויחו מאות אלפי דולרים מהחדר בבית.
- אתם מתחילים מאפס — ובסוף הקורס תבצעו בדיקת חדירות מלאה בעצמכם. 🚀

🎯 **המטרה שלנו:** בכל אחד מהסיפורים לעיל, אילו האקר אתי היה בודק את המערכת **מראש** — האסון היה נמנע. **זה** מה שאתם הולכים ללמוד לעשות.

1.1 מהו האקינג אתי (Ethical Hacking)?

האקינג אתי הוא תהליך מורשה וחוקי של הערכת אבטחת מערכת, רשת או אפליקציה, על-ידי סימולציה של תקיפה אמיתית — במטרה למצוא חולשות (Vulnerabilities) **לפני** שתוקף זדוני ינצל אותן. המבצע נקרא בודק חדירות (**Penetration Tester / Pentester**) או **האקר אתי (Ethical Hacker)**.

הרעיון המרכזי: כדי להגן על מערכת, צריך לחשוב כמו התוקף. ההאקר האתי משתמש באותם כלים ובאותן טכניקות של הפושע — אך בהבדל מהותי אחד: הרשאה.

שלושת עמודי התווך של המקצוע — CIA Triad

כל עולם אבטחת המידע נשען על שלושה עקרונות. מטרת התוקף היא לפגוע באחד מהם, ומטרת ההאקר האתי היא לוודא שהם מוגנים:

עיקרון	פירוש	דוגמה לפגיעה
Confidentiality (סודיות)	רק מורשים רואים את המידע	דלף מסד נתונים של סיסמאות
Integrity (שלמות)	המידע לא שונה ללא הרשאה	שינוי סכום בהעברה בנקאית
Availability (זמינות)	המערכת זמינה למשתמשים	מתקפת מניעת שירות (DoS)

 **דוגמה מהחיים:** כשבודק חדירות מוצא שאפשר לקרוא קבצים של משתמשים אחרים — זו פגיעה ב-Confidentiality. כשהוא מראה שאפשר לשנות הרשאות — זו פגיעה ב-Integrity. כל ממצא בדוח מסווג לפי העיקרון שנפגע.

ההבדל בין האקר אתי לתוקף זדוני

ההבדל אינו בכלים — הוא בהרשאה ובכוונה:

האקר אתי (White Hat)	תוקף זדוני (Black Hat)	
חווה והסכמה בכתב	ללא הרשאה	הרשאה
תיקון וחיזוק ההגנה	גניבה, נזק, רווח	מטרה
דוח מפורט ללקוח	הסתרת עקבות	תיעוד
חוקי	עבירה פלילית	חוקיות

1.2 סוגי האקרים (Threat Actors)

בעולם האמיתי יש קשת של "שחקנים". חשוב להכיר אותם — הן להבנת האיום, הן כי זו שאלה נפוצה בראיונות:

- **White Hat (כובע לבן):** האקר אתי הפועל בהרשאה ולמטרות הגנה. זה אנחנו.
- **Black Hat (כובע שחור):** תוקף זדוני, ללא הרשאה, למטרות רווח/נזק.
- **Grey Hat (כובע אפור):** פועל ללא הרשאה מלאה אך לא בהכרח בזדון (למשל מוצא חולשה ומדווח — אך הפעולה עצמה לא הייתה מורשית).
- **Script Kiddie:** חסר ידע עמוק, מריץ כלים מוכנים של אחרים בלי להבין.
- **Hacktivist:** תוקף ממניעים אידאולוגיים/פוליטיים (למשל Anonymous).
- **State-Sponsored / APT:** קבוצות מתקדמות במימון מדינות (Advanced Persistent Threat), עם משאבים עצומים.
- **Insider Threat (איום פנימי):** עובד בארגון שמנצל את גישתו לרעה.

💡 **מדוע זה חשוב לבדיקה?** כשמתכננים בדיקת חדירה, מגדירים את "פרופיל התוקף" שאותו מדמים — למשל "תוקף חיצוני ללא פרטי גישה" מול "עובד זדוני עם חשבון משתמש רגיל". הפרופיל קובע את נקודת ההתחלה.

1.3 סוגי בדיקות חדירה (Types of Penetration Tests)

לפי כמות המידע שנמסר לבודק

- **Black Box (קופסה שחורה):** הבודק מקבל מידע מינימלי (למשל רק שם דומיין). מדמה תוקף חיצוני אמיתי. איטי יותר אך ריאלי.
- **White Box (קופסה לבנה):** הבודק מקבל גישה מלאה — קוד מקור, דיאגרמות, פרטי גישה. יסודי ומהיר יותר.
- **Grey Box (קופסה אפורה):** אמצע — מידע חלקי (למשל חשבון משתמש רגיל). הנפוץ ביותר בפועל.

לפי סוג היעד (Engagement Types)

- **External Network** — תקיפת הנכסים החשופים לאינטרנט.

- **Internal Network** — תקיפה מתוך הרשת הפנימית (מדמה עובד/מכונה שנפרצה). כאן נכנס **Active Directory**.
- **Web Application** — חולשות באפליקציות (OWASP).web
- **Wireless** — רשתות Wi-Fi.
- **Social Engineering** — תקיפת הגורם האנושי (פישונג).
- **Physical** — חדירה פיזית למתקן.

הקורס הזה מתמקד בעיקר ב-Web, Internal (AD), Wireless-1 External — בדיוק כמו בדיקת חדירות מקצועית טיפוסית.

1.4 מושגי יסוד וטרמינולוגיה

לפני שנצלול, נגדיר מונחים שילוו אותנו לכל אורך הקורס. **בלבול בין המונחים האלה הוא טעות נפוצה של מתחילים:**

מונח	הגדרה	דוגמה
Vulnerability (חולשה)	חולשה או פגם במערכת	גרסת Apache ישנה עם באג ידוע
Exploit (ניצול)	קוד/טכניקה המנצלים חולשה	סקריפט שמפעיל את הבאג ומשיג שליטה
Payload (מטען)	מה שרץ אחרי הניצול	Shell שנפתח, הוספת משתמש
Threat (איום)	גורם פוטנציאלי לנזק	האקר, תוכנה זדונית
Risk (סיכון)	הסתברות × נזק	סיכון גבוה = חולשה קריטית בקלות ניצול
Attack Surface	סך נקודות הכניסה האפשריות	כל הפורטים, השירותים והדפים החשופים
Zero-Day	חולשה שאין לה עדיין תיקון	באג לא ידוע ליצרן

נוסחת הזהב: $Vulnerability + Exploit + Payload =$ גישה. כלומר: מוצאים **חולשה**, מפעילים עליה **Exploit**, שמריץ **Payload** שנותן לנו שליטה.

💡 **דוגמה מוחשית:** דלת נעולה עם מנעול פגום = **Vulnerability**. שיטת פריצת המנעול = **Exploit**. מה שאתה עושה אחרי שנכנסת (גונב/מצלם) = **Payload**.

🎬 הדגמה — נסה בעצמך: הפריצה הראשונה שלך 🚀

אין צורך במעבדה/VM עדיין — רק פייתון. נהפוך את "נוסחת הזהב" למשהו שתעשה **במו ידיך**.

צעד 1 — הרץ את היעד (הקובץ `first_hack.py` בתיקיית המודול):

```
python3 first_hack.py
```

👁️ "כספת" מבקשת סיסמה. אם תנחש — תיכשל. האקר לא מנחש, הוא **חוקר**.

צעד 2 — איסוף מידע (Recon): הצץ ביעד. לחץ `Ctrl+C` ליציאה, ואז:

```
cat first_hack.py
```

👁️ חפש שורה עם `SECRET_PASSWORD = "..."` — זו ה**חולשה**: סיסמה קשיחה גלויה בקוד.

צעד 3 — ניצול (Exploit): השתמש במה שמצאת. הרץ שוב והדבק את הסיסמה:

```
python3 first_hack.py
```

👁️ הכספת נפתחת ומדפיסה `flag{...}` — זה ה**מטען (Payload)** שלך.

צעד 4 — דרך שנייה (כמו האקר אמיתי): לא תמיד קוראים קוד מקור. נסה כלי חילוף מחרוזות:

```
strings first_hack.py | grep -i "password\\|flag"
```

👁️ אותה סיסמה ואותו דגל — בלי לקרוא את כל הקובץ. **לכל יעד יש כמה דרכים פנימה.**

🎯 **מה קרה כאן:** מימשת את גישה `Vulnerability + Exploit + Payload =` על יעד אמיתי. מצאת חולשה (סיסמה בקוד), ניצלת אותה (קראת/חילצת), וקיבלת מטען (הדגל). **זה כל המקצוע, בזעיר אנפין.**

🏆 **בונים — מצא את הדלת האחורית:** בקוד מסתתרת גם **Backdoor** (דלת אחורית שהמפתח שכח). מצא אותה ב-`cat`, והיכנס דרכה. 💡 חפש `backdoor` בקוד.

🧠 **בדוק את עצמך:** בהדגמה, מהי ה**חולשה (Vulnerability)?** - א) שהתוכנית כתובה בפייתון - ב) שהסיסמה נשמרה גלויה בתוך קוד המקור - ג) ש-`strings` היא פקודה מסוכנת

1.5 חמשת שלבי ההאקינג האתי (The Five Stages)

זהו הלב של הקורס. כל בדיקת חדירה — בלי קשר ליעד — עוברת דרך אותה מתודולוגיה בסדר קבוע. הכלים משתנים, המתודולוגיה לא.

שלב 1 — איסוף מידע (Reconnaissance)

איסוף כמה שיותר מידע על היעד. מתחלק ל: - **פסיבי (Passive)**: ללא מגע ישיר — Google, LinkedIn, דלף מידע. - **אקטיבי (Active)**: מגע ישיר — סריקה עם כלים כמו nmap.

דוגמה: מציאת כתובות מייל של עובדים ב-hunter.io (פסיבי) ← מודול 5.

שלב 2 — סריקה ומיפוי (Scanning & Enumeration)

זיהוי פורטים פתוחים (Open Ports), שירותים (Services), גרסאותיהם וחולשות אפשריות.

דוגמה: גילוי שפורט 80 פתוח ומריץ Apache 2.4.49 — גרסה עם חולשת Path Traversal ידועה ← מודול 6.

שלב 3 — השגת גישה (Gaining Access / Exploitation)

ניצול חולשה שהתגלתה כדי לחדור למערכת.

דוגמה: הפעלת Exploit מתאים ב-Metasploit נגד ה-Apache הפגיע, וקבלת Shell ← מודול 7.

שלב 4 — שמירת גישה (Maintaining Access)

שמירה על הגישה גם לאחר אתחול/ניתוק — למשל התקנת "דלת אחורית" (Backdoor) או משתמש נוסף.

דוגמה: הוספת מפתח SSH כדי לחזור למערכת בכל עת ← מודול 11.

שלב 5 — טשטוש עקבות (Covering Tracks)

מחיקת לוגים, קבצים וכלים שהושארו, כדי שהחדירה לא תזוהה. בבדיקה **אתית** — המטרה היא לנקות אחריו ולהחזיר את המערכת למצבה.

⚠️ **טעות נפוצה:** דילוג על שלב 1. מתחילים נוטים "לקפוץ" ישר לתקיפה. בפועל, **80% מהצלחת הבדיקה תלויה באיכות איסוף המידע**. תוקף שמכיר את היעד לעומק — מנצח.

💡 **שאלת ראיון קלאסית:** "תאר את חמשת שלבי ההאקינג האתי". שכן אותם בעל פה ובסדר הנכון: **Recon → Scanning → Gaining Access → Maintaining Access → Covering Tracks**

🎬 **הדגמה — נסה בעצמך: חמשת השלבים בזעיר אנפין**

נעבור על כל חמשת השלבים במיני-סימולציה על המחשב שלך — כדי שהמתודולוגיה תהיה מוחשית.

שלב	פקודה לנסות	מה זה מדמה
1. Recon	<code>whoami && ip a</code> (או <code>ifconfig</code>)	מי אני ומה כתובת ה-IP שלי
2. Scanning	<code>ss -tulpn</code>	אילו "דלתות" (פורטים) פתוחות במכונה
3. Gaining Access	<code>python3 first_hack.py</code> → פרוץ עם הסיסמה	ניצול חולשה וקבלת גישה
4. Maintaining Access	<code>echo "echo BACKDOOR" >> ~/.bashrc && tail -1 ~/.bashrc</code>	שתילת "חזרה" אוטומטית (ואז מחק את השורה!)
5. Covering Tracks	<code>history tail</code> ו־ <code>history -c</code>	ניקוי עקבות (לוג הפקודות)

<code>whoami && ip a</code>	# שלב 1 – מי אני
<code>ss -tulpn</code>	# שלב 2 – מה פתוח
<code>python3 first_hack.py</code>	# שלב 3 – פריצה
<code>history tail</code>	# שלב 5 – מה השארתי אחריי

👁️ שים לב שכל שלב **בנוי על הקודם**: קודם מכירים את השטח, אז סורקים, ורק אז תוקפים.

🎯 **מה קרה כאן:** עשית מיני-בדיקת-חדירה מלאה בחמש פקודות. בהמשך הקורס כל שלב יהפוך למודול שלם — אבל הסדר תמיד זהה.

⚠️ אם הוספת שורה ל-`~/.bashrc` בשלב 4 — **מחק אותה עכשיו** (`nano ~/.bashrc`). האקר אתי תמיד מנקה אחריו.

🧠 **בדוק את עצמך:** לפי המתודולוגיה, מה עושים **מיד לפני** "השגת גישה" (Gaining Access - ?) (א) טשטוש עקבות - (ב) סריקה ומיפוי (Scanning & Enumeration) - (ג) כתיבת הדוח

✓ **תשובה: ב** — הסדר קבוע: Recon → **Scanning** → Gaining Access. אי אפשר לתקוף חולשה לפני שסרקת וגילית אותה.

1.6 היבטים משפטיים ואתיים

לפני כל בדיקה חייבים מסמכים משפטיים: **Scope (טווח)**: אילו נכסים מותר לתקוף. מה שמחוץ ל-Scope — **אסור**. - **Rules of Engagement (RoE)**: כללי ההתקשרות — שעות, סוגי תקיפה מותרים, אנשי קשר. - **NDA**: הסכם סודיות — הבודק נחשף למידע רגיש. - **Get-Out-of-Jail-Free Letter**: מכתב הרשאה חתום, שמוכיח שהפעולה מורשית.

⚠ **חוק ברזל**: בישראל, תקיפת מערכת ללא רשות היא עבירה פלילית לפי **חוק המחשבים, התשנ"ה-1995**. גם "רק כדי לבדוק" על מערכת של אחר = עבירה. תרגל **אך ורק** על המעבדה שלך או על יעדים מורשים (TryHackMe, HackTheBox, Bug Bounty בתוך Scope).

1.7 הקמת המעבדה (Lab Setup)

כדי לתרגל בבטחה, בונים **מעבדה וירטואלית מבודדת** — מכונות וירטואליות (VMs) הרצות על המחשב, מנותקות מהרשת האמיתית.

רכיבי המעבדה

1. **תוכנת וירטואליזציה (Hypervisor): VirtualBox** — חינמי, חוצה-פלטפורמות, ומומלץ לקורס (הוא גם הכלי שבמדריך המאויר). חלופה: **VMware Workstation Pro** (מ-2024 חינמי לשימוש אישי).
2. **מכונת תוקף: Kali Linux**.
3. **מכונות מטרה: Metasploitable 2, Kioptrix**, ובהמשך מעבדת Windows/AD.

💻 **מדריך מאויר צעד-אחר-צעד (עם צילומי מסך): resources/lab-setup-illustrated.md** — מומלץ לעקוב אחריו במקביל להתקנה, כולל פתרון תקלות נפוצות.

התקנת Kali על VirtualBox — צעד אחר צעד

1. virtualbox.org: מהאתר הרשמי VirtualBox התקן
2. Virtual Machines ← Get Kali ← kali.org -גלוש ל
3. זקובץ 7 - Kali (64-bit) של VirtualBox-הורד את דמות ה
4. .vdi ו-.vbox יתקבלו קובצי → Zip-את הקובץ עם 7 (Extract) חלק
5. VirtualBox ← Machine ← Add ← בחר את קובץ ה
6. Settings → System: RAM 2GB ליבות 2, (CPU) ליבות 2, (GB+) 8GB מומלץ 4) לפחות
7. Start (הפעל את המכונה)
8. kali / kali סיסמה / kali התחברות: משתמש

חלופה — VMware Workstation Pro (חינמי לשימוש אישי מ-2024): הורד את דמות ה-VMware מ-kali.org, פתח ב-File → Open את קובץ ה-.vmx, והפעל. שאר ההגדרות (RAM, רשת, Snapshot) זהות ברעיון.

הגדרת רשת מבודדת — קריטי! 🔒

ב-VirtualBox: VM → Settings → Network (ב-VMware) Settings → Network → Adapter 1: בחר **Host-Only** או **NAT**:

מצב רשת	משמעות	מתי
NAT	ה-VM חולק את חיבור המארח, מבודד מהרשת המקומית	ברירת מחדל בטוחה
Host-Only	רשת סגורה בין ה-VMs והמארח בלבד, ללא אינטרנט	תרגול תקיפה בין מכונות
Bridged	ה-VM מקבל IP ברשת הביתית האמיתית	⚠️ הימנע — חושף את הרשת

Snapshots — הרגל שיציל אותך

לפני כל שינוי משמעותי, ב-VirtualBox: Machine → Take Snapshot (ב-VMware): VM → Snapshot → Take Snapshot. אם משהו נשבר — חזורים בלחיצה. **קח Snapshot מיד אחרי התקנה נקייה של Kali.**

פתרון תקלות נפוצות: - "VT-x is disabled" — יש להפעיל וירטואליזציה ב-Kali - BIOS/UEFI. איטי — הגדל RAM ל-4GB, הקצה 2 ליבות. - אין רשת — ודא שהמתאם מחובר (Connected) ובמצב NAT.

הדגמה — נסה בעצמך: ודא שהמעבדה שלך חיה ומבודדת

אחרי שה-Kali עולה — לפני שממשיכים, מוודאים שהכול עובד. זה מה שבודק חדירות עושה בתחילת כל יום.

צעד 1 — מי אני ומה ה-IP שלי:

```
whoami          # אמור להחזיר: kali
ip a            # x.x.x (Host-Only) או 192.168.56.x (NAT) כתובת כמו 10.0.2.x
```

👁️ רשום לעצמך את כתובת ה-IP — נשתמש בה לאורך הקורס.

צעד 2 — יש אינטרנט? (רק אם אתה ב-NAT):

```
ping -c 3 8.8.8.8
```

👁️ שלוש תשובות = יש חיבור. אם אתה ב-Host-Only מבודד — זה **אמור** להיכשל, וזה תקין.

צעד 3 — קח **Snapshot נקי עכשיו**. ב-VirtualBox: **Machine → Take Snapshot**. שם: **clean-install**. מעכשיו, אם משהו נשבר — חוזרים לכאן בלחיצה אחת.

🎯 **מה קרה כאן:** אימתת זהות, כתובת רשת ובידוד — ויצרת רשת ביטחון (Snapshot). זו שגרת פתיחה של כל בדיקה.

🧠 **בדוק את עצמך:** באיזה מצב רשת ה-VM **מבודד לגמרי** מהרשת הביתית שלך (בלי אינטרנט? - א) (Bridged - ב) NAT - ג) Host-Only

✅ **תשובה: ג** — **Host-Only** יוצר רשת סגורה בין ה-VMs והמארח בלבד. **Bridged** דווקא חושף את ה-VM לרשת האמיתית — ולכן להימנע.

1.8 סקירת Kali Linux

Kali Linux היא הפצת לינוקס (מבוססת Debian) לבדיקות חדירה, עם 600+ כלי אבטחה מותקנים מראש.

דבר ראשון אחרי התקנה — עדכון

```
sudo apt update && sudo apt full-upgrade -y
```

- **תפריט Applications** (לוגו Kali) — כלים לפי קטגוריות.
- **Terminal** — סביבת העבודה המרכזית; כאן “נחיה” כל הקורס.
- **Firefox** — הדפדפן המובנה (שימושי ל-Burp Suite).

קטגוריות הכלים — עם דוגמאות אמיתיות

קטגוריה	תפקיד	כלי לדוגמה	שימוש לדוגמה
Information Gathering	איסוף מידע	nmap	<code>nmap -sV 10.0.0.5</code>
Vulnerability Analysis	ניתוח חולשות	nikto	<code>nikto -h http://10.0.0.5</code>
Web Application	חולשות web	Burp Suite	Proxy לתעבורת HTTP
Password Attacks	תקיפת סיסמאות	hydra	<code>hydra -l admin -P rockyou.txt ...</code>
Exploitation	ניצול	Metasploit	<code>msfconsole</code>
Sniffing & Spoofing	האזנה	Wireshark	לכידת תעבורת רשת
Post Exploitation	לאחר חדירה	mimikatz	שאיבת סיסמאות מהזיכרון

💡 אין צורך לשנן את כל הכלים עכשיו — נכיר אותם בהדרגה, כל אחד בשלב המתאים.

מבנה מערכת הקבצים (נקודות מפתח)

- `/etc` — קבצי הגדרות המערכת.
- `/home/kali` — תיקיית הבית שלך.
- `/usr/share/wordlists` — רשימות מילים לתקיפת סיסמאות (כולל `rockyou.txt`).
- `/opt` — כלים שהותקנו ידנית.
- `/tmp` — קבצים זמניים (שימושי בזמן תקיפה).

(את פקודות ה-Linux עצמן נלמד לעומק במודול 2 — יסודות Linux).

נכיר את הכלים ש"נחיה" איתם — בלי לתקוף עדיין, רק לראות שהם שם ומוכנים.

צעד 1 — הכלים כבר מותקנים? בדוק שלושה מפורסמים:

```
nmap --version          # סורק הרשתות
hydra -h | head -5       # תוקף הסיסמאות
msfconsole --version     # מסגרת הניצול Metasploit
```

👁️ כל אחד מחזיר גרסה = הוא מותקן ומוכן.

צעד 2 — מצא את רשימת הסיסמאות המפורסמת בעולם:

```
ls -lh /usr/share/wordlists/
zcat /usr/share/wordlists/rockyou.txt.gz 2>/dev/null | head -10 || head -10 /usr/share/wordlists/
```

👁️ rockyou.txt — 14 מיליון סיסמאות אמיתיות שדלפו. נשתמש בה במודול 8. (אם דחוסה: gunzip אותה.)

צעד 3 — לאן הכלים מחולקים? פתח את תפריט Applications (לוגו Kali) וראה את הקטגוריות: Information Gathering, Web Application, Password Attacks ... 👁️ בדיוק חמשת השלבים שלמדת — הכלים מסודרים לפי שלב.

🎯 **מה קרה כאן:** ראית שארגז הכלים כבר מלא ומסודר לפי מתודולוגיה. אין צורך לשנן — כל כלי יגיע בשלב שלו.

🧠 **בדוק את עצמך:** איפה נמצאות רשימות המילים (Wordlists) לתקיפת סיסמאות ב-Kali? (א - /etc/passwords/ (ב - /usr/share/wordlists/ (ג - /home/kali/

✅ **תשובה: ב** — /usr/share/wordlists/ מכילה את rockyou.txt ועוד. זו נקודת התחלה לכל מתקפת סיסמאות.

סיכום המודול

- **האקינג אתי** = בדיקה **מורשית** למציאת חולשות לפני התוקף, המגנה על ה-CIA Triad.
- מכירים את **סוגי ההאקרים** (...White/Black/Grey) ואת **סוגי הבדיקות** (Black/White/Grey Box; External/Internal/Web ...).

- שולטים בטרמינולוגיה: **Vulnerability + Exploit + Payload = גישה**.
- **חמשת השלבים**: Recon → Scanning → Gaining Access → Maintaining Access → Covering Tracks.
- כל פעולה מחייבת **הרשאה משפטית** (Scope, RoE, NDA).
- הקמנו **מעבדה מבודדת** עם Kali (תוקף) + מטרות, והכרנו את Kali וארגו הכלים.

מילון מונחים מהיר

Recon · Enumeration · Vulnerability · Exploit · Payload · Attack Surface · Scope · RoE · CIA Triad · Hypervisor · Snapshot

מה הלאה?

→ **תרגילים** — `missions.md` (קל → קשה) · לאחר מכן **פתרונות** — `solutions.md` · **תרגול**
ותרחישים — `practice.md` → המודול הבא: **מודול 2 — יסודות Linux**

← חזרה למפת הקורס